

Rapport détaillé d'analyse EBIOS RM – Belhome

1. Présentation de la mission

La mission confiée consiste à analyser les risques cyber pesant sur Belhome à la suite de deux appels d'offres perdus dans des circonstances inhabituelles. Le dirigeant soupçonne une fuite d'information mais ne dispose d'aucune preuve permettant de confirmer cette hypothèse. La démarche retenue consiste donc à objectiver la situation au travers d'une analyse de risque structurée. L'objectif n'est pas de rechercher un responsable ou de démontrer qu'une compromission a eu lieu. L'objectif est d'identifier les actifs critiques de l'entreprise, de comprendre les scénarios plausibles permettant leur compromission et de déterminer les mesures de sécurité les plus adaptées aux contraintes d'une TPE.

2. Pourquoi utiliser la méthode EBIOS

La méthode EBIOS Risk Manager développée par l'ANSSI permet d'analyser les risques en partant des enjeux métiers. Cette approche est particulièrement pertinente pour Belhome car l'entreprise dispose de ressources limitées et ne peut pas protéger l'ensemble de son système d'information avec le même niveau d'exigence. EBIOS permet d'éviter une approche purement technique centrée sur les outils. La réflexion commence par les conséquences métier d'un incident avant d'étudier les vulnérabilités techniques susceptibles de conduire à cet incident. Cette logique garantit que les investissements de sécurité répondent réellement aux besoins de l'entreprise.

3. Étude du contexte métier

Belhome est un bureau d'études spécialisé dans les structures. Son activité repose principalement sur les compétences de ses ingénieurs et sur les études produites pour ses clients. Le secteur présente plusieurs spécificités : - forte concurrence sur les appels d'offres ; - forte valeur du savoir-faire technique ; - responsabilité professionnelle importante ; - conservation longue durée des dossiers ; - dépendance à la réputation. Ces éléments expliquent pourquoi certaines informations possèdent une valeur stratégique particulièrement élevée.

4. Identification des biens essentiels

Les biens essentiels correspondent aux actifs indispensables à la réalisation de la mission de l'entreprise. BE1 – Études techniques : Elles constituent le cœur de l'activité. Elles contiennent les calculs, hypothèses, méthodes et résultats produits par les ingénieurs. Leur perte, leur vol ou leur altération aurait un impact direct sur l'activité. BE2 – Données commerciales : Ces informations regroupent les prix, marges, devis, réponses aux appels d'offres et négociations commerciales. Elles représentent un avantage concurrentiel majeur. BE3 – Correspondances : Les échanges de messagerie assurent la coordination entre les collaborateurs, clients et partenaires. BE4 – Données administratives et RH : Ces données sont soumises à des obligations légales et réglementaires, notamment au RGPD.

5. Justification détaillée des critères C-I-D

Confidentialité : Les études techniques et les prix doivent rester confidentiels afin d'éviter l'espionnage économique. Intégrité : L'intégrité des études est considérée comme critique. Une erreur ou une modification non détectée pourrait avoir des conséquences majeures sur la qualité des ouvrages réalisés. Disponibilité : Les données doivent rester accessibles afin d'assurer la continuité des activités et le respect des engagements contractuels. La notation attribuée à chaque bien essentiel résulte directement de l'analyse des conséquences métier associées à une atteinte sur chacun de ces critères.

6. Analyse approfondie des biens supports

Les biens supports sont les éléments qui hébergent, transportent ou permettent l'exploitation des biens essentiels. L'étude met en évidence plusieurs catégories : - postes de travail ; - serveurs ; - supports amovibles ; - infrastructures réseau ; - locaux ; - intervenants humains. L'analyse révèle que les clés USB et les accès physiques constituent des points d'exposition particulièrement importants. Contrairement à une idée répandue, le risque principal n'est pas nécessairement une attaque distante mais un usage quotidien insuffisamment sécurisé.

7. Construction des événements redoutés

Événement redouté n°1 : fuite des données commerciales. Cet événement est retenu car il constitue l'explication la plus directe à la perte répétée d'appels d'offres. Si un concurrent obtient les prix proposés par Belhome, il peut ajuster ses propres offres avec une précision importante. Événement redouté n°2 : compromission des études techniques. Cet événement inclut la divulgation, l'altération ou la destruction des études. Il est considéré comme prioritaire car ses conséquences dépassent largement le cadre économique et peuvent affecter la responsabilité professionnelle des ingénieurs.

8. Analyse détaillée du scénario R1

Source de menace : concurrent cherchant un avantage commercial. Objectif : obtenir les prix proposés aux clients. Vulnérabilités : - documents imprimés ; - poste portable du commercial ; - supports amovibles ; - sensibilisation limitée. Chaîne d'attaque : 1. collecte d'informations ; 2. compromission ou récupération des données ; 3. analyse des prix ; 4. adaptation des offres concurrentes. Impacts : - perte d'appels d'offres ; - diminution des marges ; - perte de compétitivité ; - dégradation de la confiance interne.

9. Analyse détaillée du scénario R2

Source de menace : concurrent, visiteur malveillant ou prestataire. Objectif : accéder aux études techniques. Vulnérabilités : - ports USB ouverts ; - accès physique ; - contrôles limités ; - absence de supervision systématique. Chaîne d'attaque : 1. accès à un équipement ; 2. introduction d'un support compromis ; 3. copie ou modification des données ; 4. exfiltration ; 5. exploitation des informations obtenues. Les conséquences potentielles incluent la perte de savoir-faire, l'atteinte à la réputation, des litiges juridiques et des responsabilités professionnelles importantes.

10. Évaluation des risques

L'évaluation repose sur deux dimensions : la gravité et la vraisemblance. Le scénario R2 obtient la priorité la plus élevée car ses conséquences sont critiques. Même avec une probabilité modérée, l'impact potentiel justifie un traitement prioritaire. Le scénario R1 est également important car il touche directement les résultats économiques de l'entreprise. La matrice de criticité permet ainsi de hiérarchiser les actions à mener.

11. Traitement des risques

Quatre stratégies existent : réduire, éviter, transférer ou accepter. Pour R2 : - réduction par chiffrement ; - réduction par contrôle des accès ; - évitement partiel via la restriction USB ; - transfert partiel via assurance cyber. Pour R1 : - chiffrement ; - VPN ; - EDR ; - cloisonnement des accès ; - procédures documentaires. Ces mesures ont été retenues car elles présentent un bon rapport efficacité/coût.

12. Analyse approfondie des risques résiduels

Le risque résiduel représente le niveau de risque subsistant après déploiement des mesures de sécurité. R2 demeure le risque principal. Même après chiffrement et contrôle physique, une menace interne, une erreur humaine ou une vulnérabilité inconnue peuvent toujours provoquer un incident. La gravité potentielle restant élevée, ce risque doit faire l'objet d'une surveillance continue. R1 est fortement réduit mais ne peut être supprimé. Les données commerciales doivent rester accessibles aux équipes afin de permettre la réalisation des missions quotidiennes. Cette nécessité opérationnelle crée mécaniquement une exposition résiduelle. R4 relatif aux données personnelles est réduit grâce aux mesures RGPD mais demeure exposé aux erreurs humaines. Les incidents les plus fréquents dans ce domaine proviennent souvent d'erreurs d'envoi ou de mauvaises pratiques documentaires. L'acceptation du risque résiduel ne signifie pas l'absence d'action. Elle signifie que l'organisation considère que le niveau atteint est compatible avec ses ressources et ses objectifs.

13. Conduite du changement et gouvernance

Le succès du plan de traitement dépend de l'adhésion des collaborateurs. Les ingénieurs doivent comprendre que les mesures de sécurité protègent leur responsabilité professionnelle. La direction doit soutenir les nouvelles pratiques dans la durée. La sensibilisation régulière constitue un élément essentiel du dispositif de sécurité car le facteur humain reste présent dans la majorité des scénarios étudiés.

14. Conclusion

L'étude démontre que les préoccupations de Belhome sont cohérentes avec les vulnérabilités observées. Les principaux risques identifiés reposent davantage sur les interactions humaines, les accès physiques et les supports amovibles que sur des cyberattaques très sophistiquées. Les mesures proposées permettent de réduire significativement l'exposition tout en restant compatibles avec les contraintes d'une TPE. La poursuite de la démarche pourrait inclure un audit technique, une analyse EBIOS RM complète et des contrôles réguliers permettant de vérifier l'efficacité des mesures mises en œuvre.